

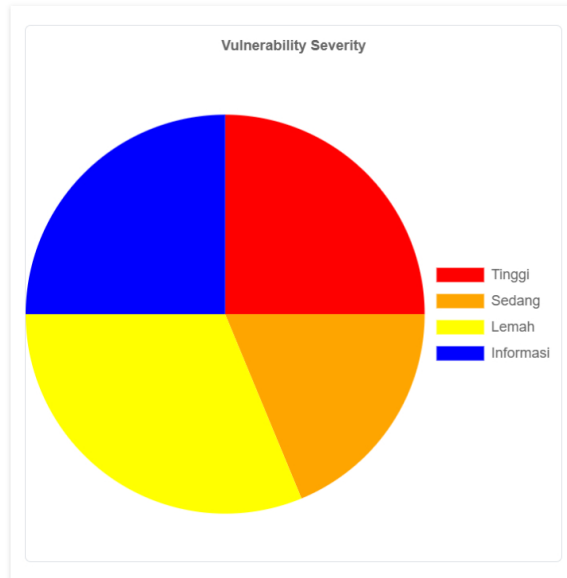
Generated on Sab, 1 Agu 2026 07:57:50

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Most Severe Alert

High

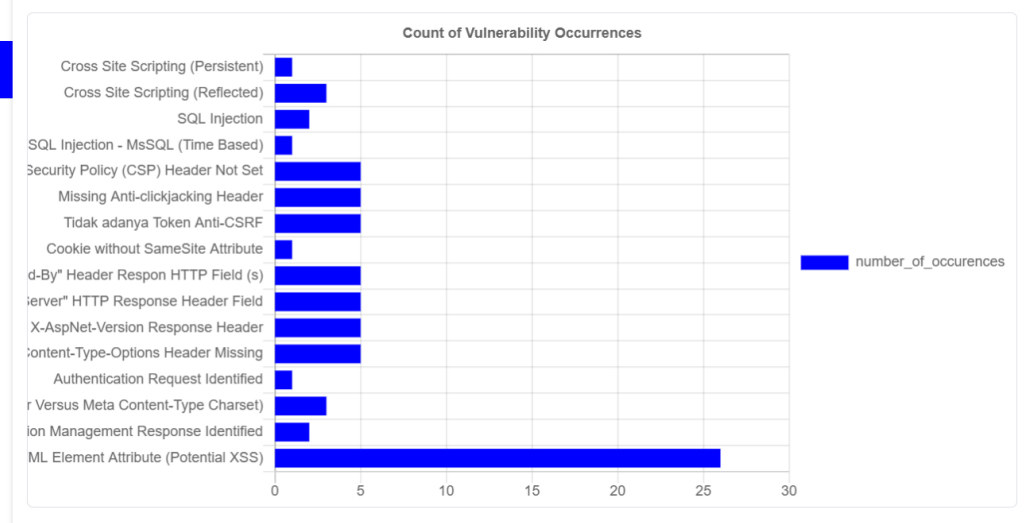


Report Description

- Laporan ini ditulis dan disusun oleh :
- Habib Muzakki (Habib)
- Alumni Kelas 12 Agama (jurusan Agama)
- Alumni MAN 2 KOTA SERANG
- Mahasiswa D4 Vokasi Teknik Informatika (Universitas Harkat Negeri Tegal)
- Wota JKT48 (Fans JKT48)
- Si pemula dan calon Cyber Security dan Bug Hunter (Bug Bounty)

Most Common Bug

User Controllable HTML Element Attribute (Potential XSS) (26)



Insights

Level	Alasan	Site	Deskripsi	Statistic
Lemah	Peringatan		ZAP warnings logged - see the zap.log file for details	9
Lemah	Exceeded High	http://testaspnet.vulnweb.com	Percentage of slow responses	100 %
Info	Informasi		Percentage of network failures	1 %
Info	Informasi	http://testaspnet.vulnweb.com	Percentage of responses with status code 2xx	95 %
Info	Informasi	http://testaspnet.vulnweb.com	Percentage of responses with status code 3xx	1 %
Info	Informasi	http://testaspnet.vulnweb.com	Percentage of responses with status code 4xx	1 %
Info	Informasi	http://testaspnet.vulnweb.com	Percentage of responses with status code 5xx	3 %
Info	Informasi	http://testaspnet.vulnweb.com	Percentage of endpoints with content type image/gif	20 %
Info	Informasi	http://testaspnet.vulnweb.com	Percentage of endpoints with content type text/css	4 %
Info	Informasi	http://testaspnet.vulnweb.com	Percentage of endpoints with content type text/html	64 %

Info	Informasi	http://testaspnet.vulnweb.com	Percentage of endpoints with content type text/plain	4 %
Info	Informasi	http://testaspnet.vulnweb.com	Percentage of endpoints with content type text/xml	4 %
Info	Informasi	http://testaspnet.vulnweb.com	Percentage of endpoints with method GET	72 %
Info	Informasi	http://testaspnet.vulnweb.com	Percentage of endpoints with method POST	28 %
Info	Informasi	http://testaspnet.vulnweb.com	Count of total endpoints	25

Vulnerability Impact

#	Name	Impact
Cross Site Scripting (Persistent) [1] [2]	Cross-site Scripting (XSS) adalah sebuah teknik serangan yang melibatkan penyerang yang bergema disediakan misalnya kode ke browser pengguna. Browser misalnya dapat menjadi standar klient browser web, atau sebuah objek browser tertanam dalam produk perangkat lunak seperti browser hanya WinAmp, aplikasi RSS reader, atau klien email. Kode itu sendiri biasanya ditulis dalam HTML/JavaScript, tetapi juga dapat memperpanjang untuk VBScript, ActiveX, Java, Flash, atau browser lain yang didukung teknologi.	
Cross Site Scripting (Reflected) [1] [2]	Cross-site Scripting (XSS) adalah sebuah teknik serangan yang melibatkan penyerang yang bergema disediakan misalnya kode ke browser pengguna. Browser misalnya dapat menjadi standar klient browser web, atau sebuah objek browser tertanam dalam produk perangkat lunak seperti browser hanya WinAmp, aplikasi RSS reader, atau klien email. Kode itu sendiri biasanya ditulis dalam HTML/JavaScript, tetapi juga dapat memperpanjang untuk VBScript, ActiveX, Java, Flash, atau browser lain yang didukung teknologi.	
SQL Injection [1]	SQL injection may be possible.	
SQL Injection - MsSQL (Time Based) [1]	SQL injection may be possible.	
Content Security Policy (CSP) Header Not Set [1] [2] [3] [4] [5] [6] [7]	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or	

	distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.	
Missing Anti-clickjacking Header [1]	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.	
Tidak adanya Token Anti-CSRF [1] [2]	Tidak ada bukti Anti-CSRF yang ditemukan dalam formulir pengiriman HTML.	
Cookie without SameSite Attribute [1]	A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks.	
Informasi Server Leaks via "X-Powered-By" Header Respon HTTP Field (s) [1] [2]	Server web/aplikasi membocorkan informasi melalui satu atau lebih header respon HTTP "X-Powered-By". Akses terhadap informasi semacam itu dapat mempermudah penyerang untuk mengidentifikasi kerangka/komponen lain yang bergantung pada aplikasi web Anda dan kerentanan komponen semacam itu dapat dikenai.	
Server Leaks Version Information via "Server" HTTP Response Header Field [1] [2] [3]	The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.	
X-AspNet-Version Response Header [1] [2]	Server kebocoran informasi melalui "X-AspNet-Version"/"X-AspNetMvc-Version" header header respon HTTP(s).	
X-Content-Type-Options	The Anti-MIME-Sniffing header X-Content-Type-	

Header Missing [1] [2]	Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.	
Authentication Request Identified [1]	The given request has been identified as an authentication request. The 'Other Info' field contains a set of key=value lines which identify any relevant fields. If the request is in a context which has an Authentication Method set to "Auto-Detect" then this rule will change the authentication to match the request identified.	
Charset Mismatch (Header Versus Meta Content-Type Charset) [1]	This check identifies responses where the HTTP Content-Type header declares a charset different from the charset defined by the body of the HTML or XML. When there's a charset mismatch between the HTTP header and content body Web browsers can be forced into an undesirable content-sniffing mode to determine the content's correct character set.	
Session Management Response Identified [1]	The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.	
User Controllable HTML Element Attribute (Potential XSS) [1]	This check looks at user-supplied input in query string parameters and POST data to identify where certain HTML attribute values might be controlled. This provides hot-spot detection for XSS (cross-site scripting) that will require further review by a security analyst to determine exploitability.	

